

Digital Vengeance

Exploiting the Most Notorious C&C Toolkits

@professor__plum

>\$ whoami

plum

>\$ finger

Login	Name	TTY	Idle	Login	Time	Office
plum	@Professor__Plum	pts/2		Sun	09:39	bc.symantec.com
plum	@Professor__Plum	pts/0	3yr	Tue	18:21	gin.bluecoat.com
plum	@Professor__Plum	pts/3	5yr	Fri	02:48	???.nsa.gov

>\$ █

Disclaimer

- ✦ The views expressed herein do not necessarily state or reflect the views of my current or former employers.
- ✦ I am not responsible for any use or misuse of the information provided.
- ✦ Implementation of the information given is at your own risk.

Backstory

The sophisticated attack

“... identified an **extremely sophisticated** cyber attack”

RSA

“Government and non-government entities are under constant attack by evolving and **advanced persistent threats** and criminal actors. These adversaries are **sophisticated, well-funded, and focused.**”

Office of Personnel Management

"The threat is very **persistent, adaptive** and **sophisticated** – and it is here to stay,”

SWIFT

“The malware that was used would have slipped or probably got past 90% of internet defenses that are out there today in private industry”

Joseph Demarest, assistant director of the FBI’s cyber division

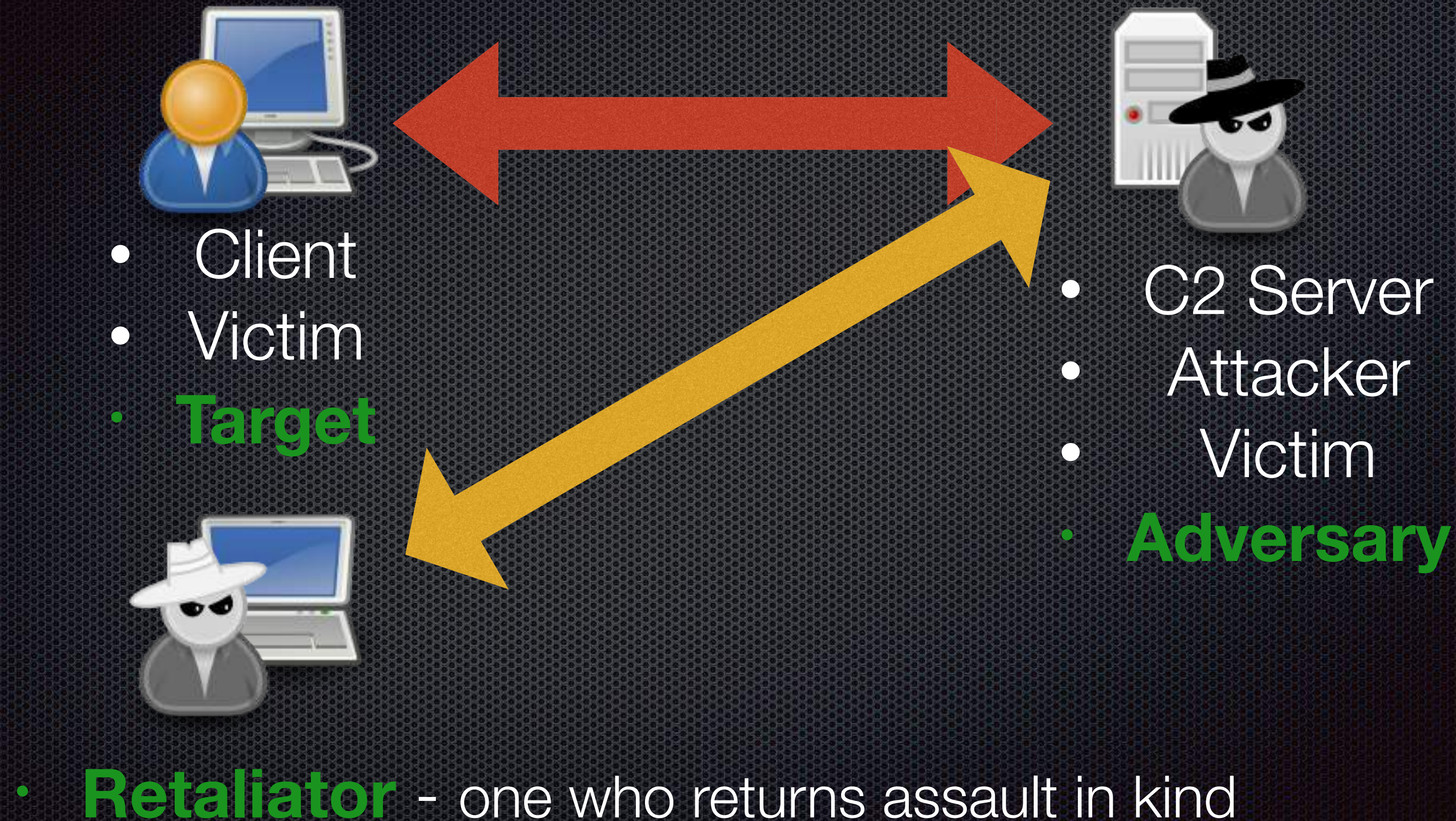
“hackers obtained data on tens of millions of current and former customers and employees in a **sophisticated** attack“

Anthem

"It is **simply not possible** to beat these hackers”

James A. Lewis Cybersecurity Expert at Center for Strategic and International Studies (CSIS)

RAT terminology



Sophisticated attack hit list



Armin Buescher
@armbues

Following

Top 10 malware counted by occurrence in [#APT](#) reports:

- Poison Ivy
- Gh0st RAT
- PlugX
- Xtreme RAT
- Enfal
- Derusbi
- DarkComet
- Shady RAT
- NJRat
- Wipbot

Retweets
42

Likes
18



Prior Art



Poison Ivy

Remote Administration Tool

[Home](#) - [Downloads](#) - [Screenshots](#) - [Development](#) - [Customer Portal](#) - [Links](#) - [Contact](#)

Poison Ivy 2.3.2 (latest version)

File name: PI2.3.2.rar

File size: 1536750 bytes

Mirror 1: poisonivy-rat.com

Poison Ivy 2.3.0 (old, unsupported)

File name: PI2.3.0.rar

File size: 1679943 bytes

Plugins

Optix Screen Capture (Screenshot)

Author: th3 s13az3

Language: Delphi

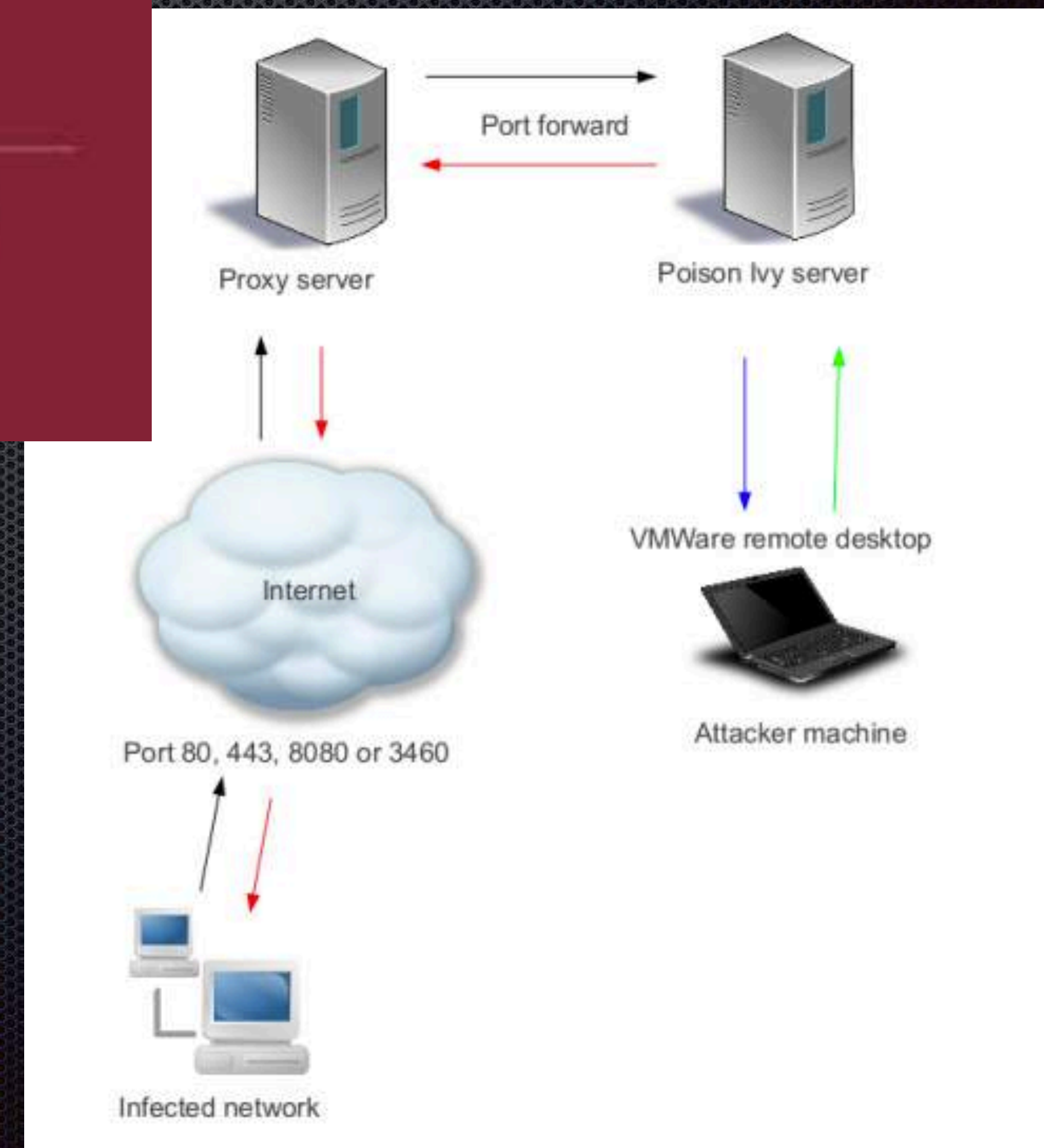
Version: 2.0.0

Binary: [Download](#)

Source: [Download](#)

- Buffer overflow exploit by Andrzej Dereszowski
- Follow on work by Jos Wetzels

APT1 & Poison Ivy



DARKCOMET

REMOTE ADMINISTRATION TOOL

- ✦ Remote file download exploit by Shawn Denbow and Jesse Hertz
- ✦ Follow on work by Jos Wetzels

New work

Gh0st RAT



红狼安全小组
C.RUFUS SECURITY TEAM

自由

我们的团队.

[进入论坛讨论](#)

CRST™
the Team

Gh0st RAT Beta 3.6

ID	WAN	LAN	Computer Name /N...	OS	CPU	Ping	Webcam
0	192.168.1.100	192.168.1.100	olum-ad771c3ed7	XP SP3 (Build 2600)	3092MHz	10	--

- File Manager
- Screen Capture
- Keylogger
- Remote Shell
- System
- Webcam View
- Audio Capture
- Administrate >
- miscellaneous >
- Change Name
- Disconnect
- Select All
- Unselect

Connections Settings

192.168.1.105

S: 0.00 kb/s R: 0.00 kb/s Port: 80 Connections: 1

ware > Musical Chairs: Multi-Year Campaign Involving New Variant of Gh0st Malware
Chairs: Multi-Year Campaign Involving New Variant of Gh0st Malware

TECHNOLOGY
Vast Spy System Loots Computers in 103 Countries

The VOHO campaign: Gh0st RAT spread by water-holing

Infamous RAT "Gh 0st RAT", used in targeted attacks targeting Taiwan

Human Rights organisation website Serves Gh0st RAT

'Night Dragon' Attacks From China Strike Energy Companies

Kunming Attack Leads to Gh0st RAT Variant

NEWS
Gh0stRAT malware attacks continue,

Many advanced persistent threat attacks use the malware, believed to be developed in China

The many faces of Gh0st Rat

Plotting the connections

ETERNALBLUE EXPLOIT SPREADING GHOST RAT,

Tracking GhostNet:

Investigating a *Cyber Espionage* Network

Amnesty UK website hacked to serve lethal Gh0st RAT Trojan

G20 2014 Summit Lure used to target Tibetan activists

Cracking Hustle, Chinese APT Group Use Zero-Day Exploit (E-2015-5119) Following Leak

Gh0st RAT

- ✦ Most notably identified by C2 traffic which start with the 5 byte marker “Gh0st” (or other 5 byte marker)

```
00000000 47 68 30 73 74 e6 01 00 00 29 04 00 00 78 9c 6d Gh0st... .)...x.m
00000010 d2 b1 b1 d3 50 10 05 d0 65 20 20 a5 03 87 94 b1 ....P... e .....
00000020 a5 a8 07 1a b8 95 30 0a 18 7a 20 db 98 9c 8c 40 .....0. .z ....@
00000030 25 fc 9c c0 1c ad 09 b1 b4 96 ac 6b 49 ef bc b7 %..... ...kI...
00000040 5f 3e 57 d5 d7 0f 55 bf de 57 bd ab 8f 75 7f 1e _>W...U. .W...u..
00000050 3f 3e d5 ff 3f d9 bd 92 d7 e1 de 9c cc 4c cd ef ?>..?... ....L..
00000060 a9 b7 9f df dd dc ea 50 82 c7 a9 46 5d 55 2e 57 .....P ...F]U.W
00000070 3f 94 93 96 b7 bc e5 2d 6f b9 4b 75 c8 0f f9 e1 ?.....- o.Ku....
```

00000, 7hero, ABCDE, Adobe, ag0ft, apach, Assas, attac, B1X6Z, BEiLa, BeiJi, Blues, ByShe, cb1st, chevr, CHINA, cyl22, DrAgOn, EXXMM, Eyes1, FKJP3, FLYNN, FWAPR, FWKJG, GWRAT, Gh0st, Gi0st, GM110, GOLDt, HEART, Hello, https, HTTPS, HXWAN, Heart, httpx, IM007, ITore, kaGni, KOBBX, KrisR, light, LkxCq, LUCKK, LURK0, lvxYT, LYRAT, Level, Lover, Lyyyy, MOUSE, MYFYB, MoZhe, MyRat, Naver, NIGHT, NoNul, Origi, OXXMM, PCRat, QQ_124971919, QWPOT, Snown, SocKt, Spidern, Super, Sw@rd, Tyjhu, URATU, v2010, VGTLS, W0LFKO, Wangz, wcker, Wh0vt, whmhl, Winds, wings, World, X6M9K, X6RAT, XDAPR, xhjyk, Xjjhj, xqwf7, YANGZ

Remote file upload

Give me C:\Documents\user\file.doc
so I can save it to targetX\file.doc



Here is the [data]
so you can save it to targetX\file.doc

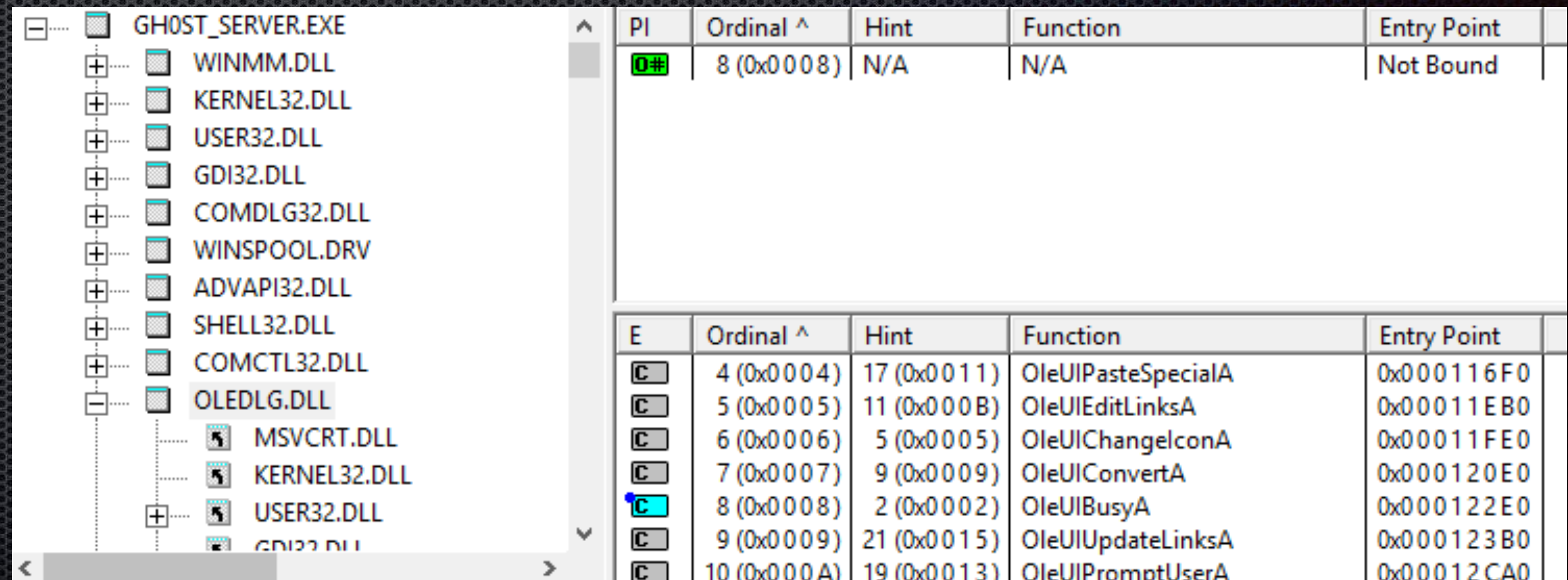
Remote file upload



Here is the [data]
so you can save it to C:\...\startup\backdoor.exe

DLL side load vulnerability

- ✦ Gh0st Server has a dependency on oledlg.dll
- ✦ Only imports one function
 - ✦ #8 OleUIBusyA(int)
- ✦ Return 1 and all is good



The screenshot shows the import table of GH0ST_SERVER.EXE. The left pane lists the DLLs it depends on, including WINMM.DLL, KERNEL32.DLL, USER32.DLL, GDI32.DLL, COMDLG32.DLL, WINSPOOL.DRV, ADVAPI32.DLL, SHELL32.DLL, COMCTL32.DLL, and OLEDLG.DLL. The right pane shows the imported functions, with OleUIBusyA (ordinal 8) highlighted.

PI	Ordinal ^	Hint	Function	Entry Point
0#	8 (0x0008)	N/A	N/A	Not Bound

E	Ordinal ^	Hint	Function	Entry Point
C	4 (0x0004)	17 (0x0011)	OleUIPasteSpecialA	0x000116F0
C	5 (0x0005)	11 (0x000B)	OleUIEditLinksA	0x00011EB0
C	6 (0x0006)	5 (0x0005)	OleUIChangelconA	0x00011FE0
C	7 (0x0007)	9 (0x0009)	OleUIConvertA	0x000120E0
C	8 (0x0008)	2 (0x0002)	OleUIBusyA	0x000122E0
C	9 (0x0009)	21 (0x0015)	OleUIUpdateLinksA	0x000123B0
C	10 (0x000A)	19 (0x0013)	OleUIPromptUserA	0x00012CA0

```
// 保存远程驱动器列表
```

```
memset(m_bRemoteDriveList, 0, sizeof(m_bRemoteDriveList));
```

```
memcpy(m_bRemoteDriveList, m_pContext->m_DeCompressionBuffer.GetBuffer(1), m_pContext->m_DeCompressionBuffer.GetBufferLen() - 1);
```

```

14  class CFileManagerDlg : public CDialog
15  {
16  // Construction
17  public:
18      bool m_bIsStop;
19      CString m_strReceiveLocalFile;
20      CString m_strUploadRemoteFile;
21      void ShowProgress();
22      void SendStop();
23      int m_nTransferMode;

```

```

43      void ShowMessage(char *lpFmt, ...);
44      CString m_Remote_Path;
45      BYTE m_bRemoteDriveList[1024];
46      CString GetParentDirectory(CString strPath);
47      void OnReceiveComplete();
48
49      CImageList* m_pImageList_Large;
50      CImageList* m_pImageList_Small;
51
52      int m_nNewIconBaseIndex; // 新加的ICON
53
54      ClientContext* m_pContext;
55      CIOCPServer* m_iocpServer;
56      CString m_IPAddress;

```

Exploitation

- ✦ Control pointer to pointer
- ✦ Could use a information disclose vuln (if I had one)
- ✦ Thus, take the lazy man's approach and heap spray
- ✦ DEP would break this but it also seems to break the EXE

Decode implant configs

- ✧ <https://github.com/kevthehermit/RATDecoders>
 - ✧ Gh0st
 - ✧ Xtreme Rat
 - ✧ Poision Ivy
 - ✧ DarkComet
 - ✧ Many others



TheHermit
kevthehermit

Malware Hunter

Finding the Command & Control Centers of Botnets across the Globe.

10+ RATs

3,000+ C2s
identified

24/ 7 Coverage

plum@Ballroom: ~

plum@Ballroom:~\$

temp

< > Home temp



Record

Show/Hide Main Window

Select Area On Screen

About

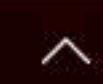
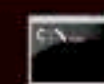
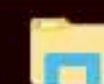
Quit



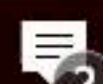
Recycle Bin



RATs

Gh0st
english.exeGh0st
english.ini

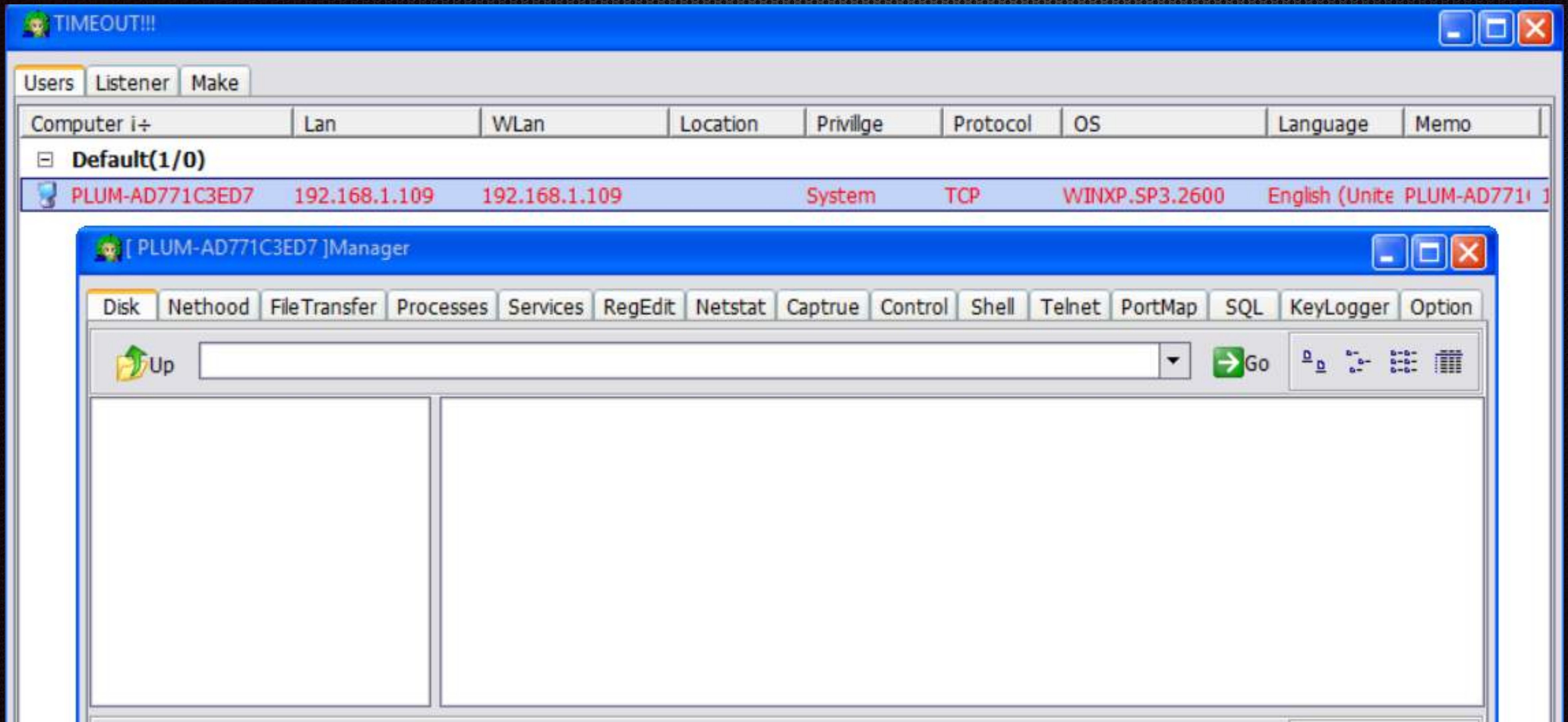
ENG

1:25 PM
6/20/2017

Post exploitation

- ✦ Netstat
 - ✦ IP address of other victims
 - ✦ May show RDP connections in (or out)
- ✦ Walk FS looking for other hacking tools
- ✦ Install persistence
- ✦ Install keylogger
- ✦ Steal credentials

PlugX / Korplug / Destory



Korplug military targeted attacks: Afghanistan & Tajikistan

BY ROBERT LIPOVSKY POSTED 12 NOV 2014 - 03:17PM

RAT

Report: PlugX Is RAT of Choice for Nation States

By Sean Michael Kerner, Posted February 13, 2015

Operation Cloud Hopper – APT10 goes after Managed Service Providers

April 6, 2017 By Pierluigi Paganini

China, Vietnam and PlugX Dominate APT Landscape

12 FEB 2015 NEWS
Tara Seals US/North America News Reporter, Infosecurity Magazine
Email Tara

The connection between the Plugx Chinese gang and the latest Internet Explorer Zeroday

PlugX RAT Used to Gather Intel on Afghan, Russian Military: Report

Eduard Kovacs on November 13, 2014

Share 26 G+1 5 Tweet Recommend 13 RSS
The notorious remote access Trojan (RAT) known as PlugX (Korplug) has been used in Afghanistan, Russia, Tajikistan, Kazakhstan and

PlugX: New Tool For a Not So New Campaign

Posted on: September 10, 2012 at 10:00 am
Author: Robert Lipovsky

PlugX used against Mongolian targets

Snorre Fagerland - November 24, 2013

The Chinese backdoor trojan PlugX has been used in a number of attacks, including a long, gradual development, and is now considered one of the most dangerous threats indicated.

Backdoor.Korplug: Loading Malicious Components Through Trusted Applications

By: Andrea Lelli

February 27, 2015

PlugX APT group uses backdoor in India campaign



A campaign aimed at organizations in India stretching out over several months and evolving, according to researchers.

OOPS, THEY DID IT AGAIN: APT TARGETS RUSSIA AND BELARUS WITH ZEROT AND PLUGX

FEBRUARY 02, 2017 Darien Huss, Pierre T, Axel F and Proofpoint Staff

SOPHOS
Security made simple.

PlugX – The Next Generation

black hat
ASIA 2014

I Know You Want Me - Unplugging PlugX

Takahiro Haruyama / Hiroshi Suzuki
Internet Initiative Japan Inc.

```
16 | ret = DecodeMsgHeader(message, message);
17 | if ( !ret )
18 | {
19 |     if ( msgHeader->size <= 0xF000u )
20 |     {
21 |         . . .
22 |
64 |     }
65 |     else
66 |     {
67 |         ShowMessage("PeDecodePacket");
68 |         ret = 13;
69 |     }
70 | }
71 | return ret;
72 | }
```

```
19 streamSize = TStream_GetSize();
20 if ( streamSize < 16 )
21     return READ_MORE_DATA;
22 v6 = *global_struct;
23 result = DecodeMsgHeader(&msgHeader, v2->TStream->buffer);
24 if ( !result )
25 {
26     messageSize = msgHeader.size + 16;
27     if ( messageSize <= streamSize )
28     {
29         memcpy(stackvar, msgHeader.size + 16, v2->TStream->buffer);
30         v8 = v2->TStream;
31         currentSize = TStream_GetSize();
32         memcpy(v2->TStream->buffer, currentSize - messageSize, &v2->TStream->buffer[messageSize]);
33         TStream = v2->TStream;
34         newStreamSize = TStream_GetSize();
35         (*TStream->SetSize)(TStream->SetSize, newStreamSize - messageSize);
36         result = DecodePacket_(*global_struct, stackvar);
37     }
38     else
39     {
40         result = READ_MORE_DATA;
41     }
42 }
43 return result;
44 }
```



```
plum@Ballroom:~$ msfconsole
```

The PGconn, PGresult, and PGError constants are deprecated, and will be removed as of version 1.0.

You should use PG::Connection, PG::Result, and PG::Error instead, respectively.

Called from /opt/metasploit-framework/embedded/lib/ruby/gems/2.4.0/gems/activesupport-4.2.8/lib/active_support/dependencies.rb:274:in `block in require'



```
= [ metasploit v4.14.28-dev- ]  
+ -- --=[ 1663 exploits - 951 auxiliary - 293 post ]  
+ -- --=[ 486 payloads - 40 encoders - 9 nops ]  
+ -- --=[ Free Metasploit Pro trial: http://r-7.co/trymsp ]
```

```
msf > 
```



Recycle Bin



RATs



PlugX.exe



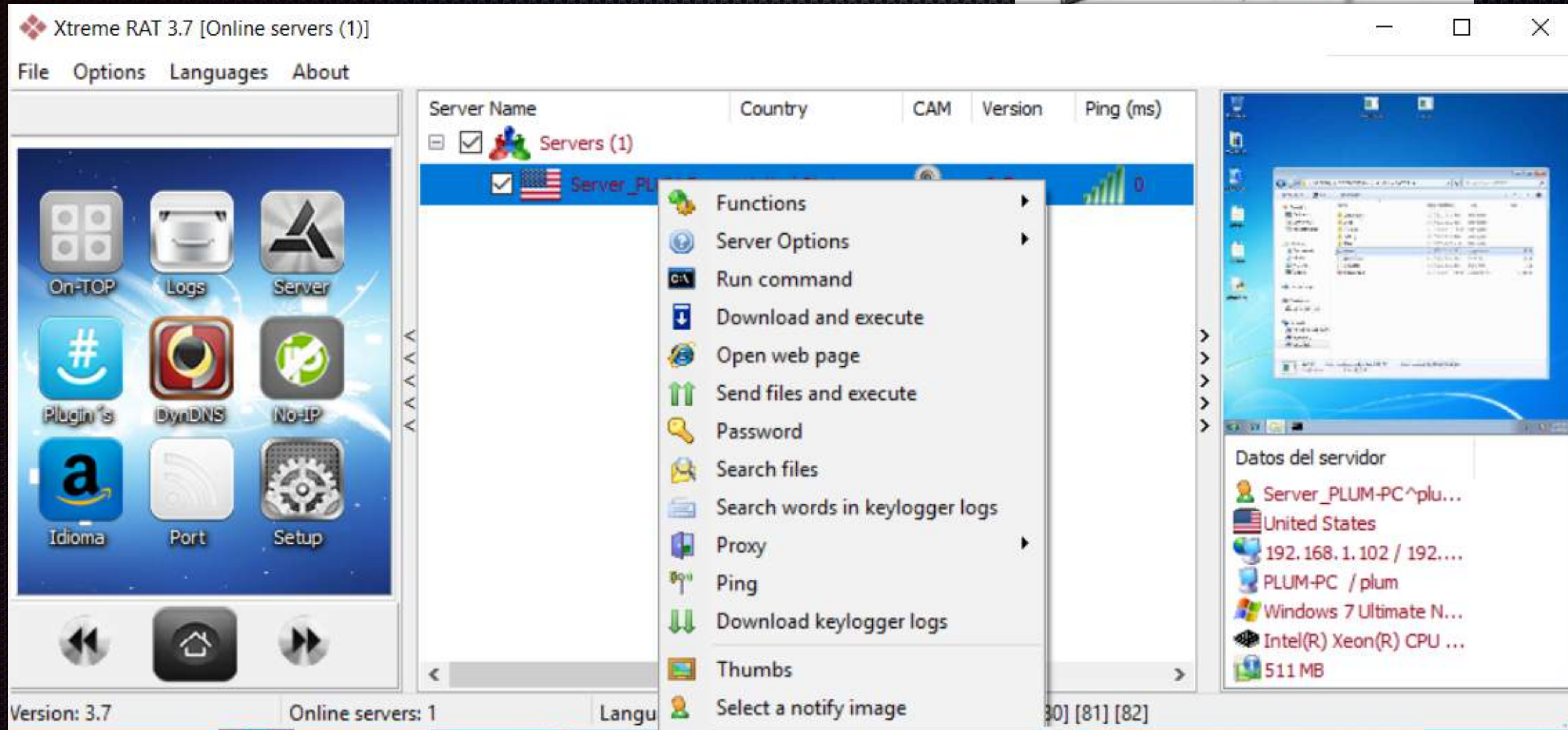
data



1:51 PM
6/20/2017



Xtreme RAT



Xtreme RAT Targets Israeli Government

Posted on: October 29, 2012 at 8:33 pm Posted in: Malware, Spam
(Security Research Manager)

Packrat: Seven Years of a South American Threat Actor

December 8, 2015

Tagged: Argentina, Brazil, Disinformation, Ecuador, I

Categories: Author, Claudio Guarnieri, John Scott-R

Authors: John Scott-Railton*, Morgan Ma

Senior Researcher, Citizen Lab, Munk School of C

Read the pr

Media cover

World, Globa

Summ

June 03, 2014

Molerats campaign turns to Xtreme RAT to target orgs

Attackers targeting organizations across the globe are now opting to use a freely available remote access trojan called **Xtreme RAT** for their exploits.

On Monday, researchers at FireEye detailed in a **blog post** how the attack campaign, dubbed "Molerats," has been ongoing since October 2011.

Over th

W32.Extrat: Syrian Conflict Used To Deliver Xtreme RAT

By: Satnam Narang SYMANTEC EMPLOYEE

8 Jan 2013



itor: Jeet A

Gaza cybergang, where's your IR team?

November 28, 2015. 8:00 am

Xtreme RAT cyberespionage targeted U.S., U.K.

Hackers dropping Zeus in favour of Xtreme RAT Trojan, reports FireEye

RATs more powerful than banking Trojans, says FireEye

Israeli police a
's say

Spyware malware found in Mexico's government

Researchers at cybersecurity firm Arbor Networks have located Xtreme RAT (Access Trojan) malware in the Mexican government's computer systems, a malicious activities found on its infrastructure.

XTREMERAT MALWARE TARGETS ISRAELI GOVERNMENT AGENCY

by Michael Mimoso

Follow @mike_mimoso

January 27, 2014, 1:28 pm

Espionage malware used in attacks against Israel, as well as Syrian activists, in the last 18 months has been linked to a new attack against Israel's Civil Administration, the governing body in the West Bank.

... of XtremeRAT, a data-stealing

Xtreme Rat

- ✦ TCP connection starts with the string “myversion|3.x\r\n”
- ✦ C2 responds with “X\r\n”
- ✦ Alternatively Xtreme rat can use a fake HTTP request of the form
GET /[0-9]{1,10}.functions

```
00000000  6d 79 76 65 72 73 69 6f  6e 7c 33 2e 37 0d 0a    myversio n|3.7..
00000000  58 0d 0a                                X..
0000000F  d2 02 96 49 00 00 00 00  16 01 00 00 00 00 00    ...I....
0000001F  78 01 ad 91 49 4e 03 31  10 45 1f 5b 24 ee 80 e0  x...IN.1 .E.[$..
0000002F  02 1d 92 ee 24 ec 98 02  62 88 98 27 b1 09 a4 13  ....$... b..'...
0000003F  86 74 80 0e b3 72 22 8e  c1 51 38 09 af 7b 11 b1  .t...r"...08...f..
```

```
GET /1234567890.functions HTTP/1.1
Accept: */*
Accept-Encoding: gzip, deflate
User-Agent: Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Tr
.NET CLR 3.0.04506.648; .NET CLR 3.5.21022)
Host: shittway.zapto.org:336
Connection: Keep-Alive
Cache-Control: no-cache
```

Remote file upload

Get ready to receive tool\bad.exe
and save it to C:\temp\calc.exe



I'm ready to receive tool\bad.exe



Here is the [data]



Remote file download

- ✦ Win.ini (Sanity check)
- ✦ Event logs
- ✦ desktop.ini
- ✦ %SYSTEMROOT%\repair\SAM
- ✦ %SYSTEMROOT%\repair\system
- ✦ https://attackerkb.com/Windows/blind_files



Summary

▪ Remote file upload in Gh0St RAT C&C

- Affected version 3.6
- A carefully crafted packet could allow a remote attacker to upload remote files to the system. The attacker can also control the file name and location of where the remote file will be stored on the remote system, with which it may be possible to gain access to the system
- Authentication is not required to exploit the vulnerability

▪ Remote code execution in Gh0St RAT C&C

- Affected version 3.6
- A carefully crafted packet could allow a remote attacker to gain code execution thereby gaining access to the system
- Authentication is not required to exploit the vulnerability

▪ Remote code execution in PlugX

- Affected versions 6.x - 7.x
- A carefully crafted packet could allow a remote attacker to gain code execution thereby gaining access to the system
- Authentication is not required to exploit the vulnerability

▪ Remote file download in XtremeRAT

- Affected versions 3.6 - 3.7
- A carefully craft packet could allow a remote attacker to retrieve any file from the remote system
- Authentication is not required to exploit the vulnerability

Thank you

@professor__plum